

INFORMATION SECURITY FUNDAMENTALS

It is important to understand how and why malicious hackers attack and exploit systems. Security professionals must protect their infrastructure against exploits by knowing the hackers who seek to use the same infrastructure for illegal activities.

Information is a critical asset that organizations must secure. If sensitive information falls into the wrong hands, organizations may suffer significant losses in terms of finances, brand reputation, and customer loyalty.

Information Security Fundamentals

Information security is the state of the well-being of information and infrastructure in which the possibility of theft, tampering, or disruption of information and services is kept low or tolerable. It is the protection or safeguarding of information systems that use, store, and transmit information from unauthorized access, disclosure, alteration, and destruction.

A **security policy** is a specification of how objects in a security domain are allowed to interact.

Need for Security

- A greater focus on ease of use with the evolution of technology
- Routine tasks rely on the use of computers for accessing, providing, or storing information
- Increased network environment and network-based applications
- The increased complexity of computer infrastructure administration and management creates a direct impact of security breach on the corporate asset base and goodwill

Elements of Information Security

Information security relies on five (5) major elements:

1. **Confidentiality:** The assurance that the information is accessible only to authorized people. Confidentiality breaches may occur due to improper data handling or a hacking attempt.

Confidentiality controls data classification, data encryption, and proper disposal of equipment such as DVDs and USB drives.
2. **Integrity:** The trustworthiness of data or resources in the prevention of improper and unauthorized changes – the assurance that information is sufficiently accurate for its purpose.

Measures to maintain data integrity may include a **checksum**, which is a number produced by a mathematical function to verify that a given block of data is not changed, and **access control**, which ensures that only authorized people can update, add to, or delete data.
3. **Availability:** The assurance that the systems responsible for delivering, storing, and processing information are accessible when required by authorized users.

Measures to maintain data availability can include disk arrays for redundant systems and clustered machines, antivirus software to combat malware, and Distributed Denial-of-Service (DDoS) prevention systems.
4. **Authenticity:** The characteristic of communication, documents, or any data that ensures the quality of being genuine or uncorrupted. The major role of authentication is to confirm that a user is authentic.

Controls such as biometrics, smart cards, and digital certificates ensure the authenticity of data, transactions, communications, and documents.

5. **Non-repudiation:** A guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message. Individuals and organizations use digital signatures to ensure non-repudiation.

The Security, Functionality, and Usability Triangle

The level of security in any system can be defined by the strength of three (3) components:

1. **Functionality:** The set of features provided by the system.
2. **Usability:** The GUI components were used to design the system for ease of use.
3. **Security:** The restrictions imposed on accessing the components of the system.

The relationship between these three (3) components is demonstrated using a triangle, as an increase or decrease in any of the components automatically affects the other components. Moving the “ball” towards any of the components means decreasing the intensity of the other components.

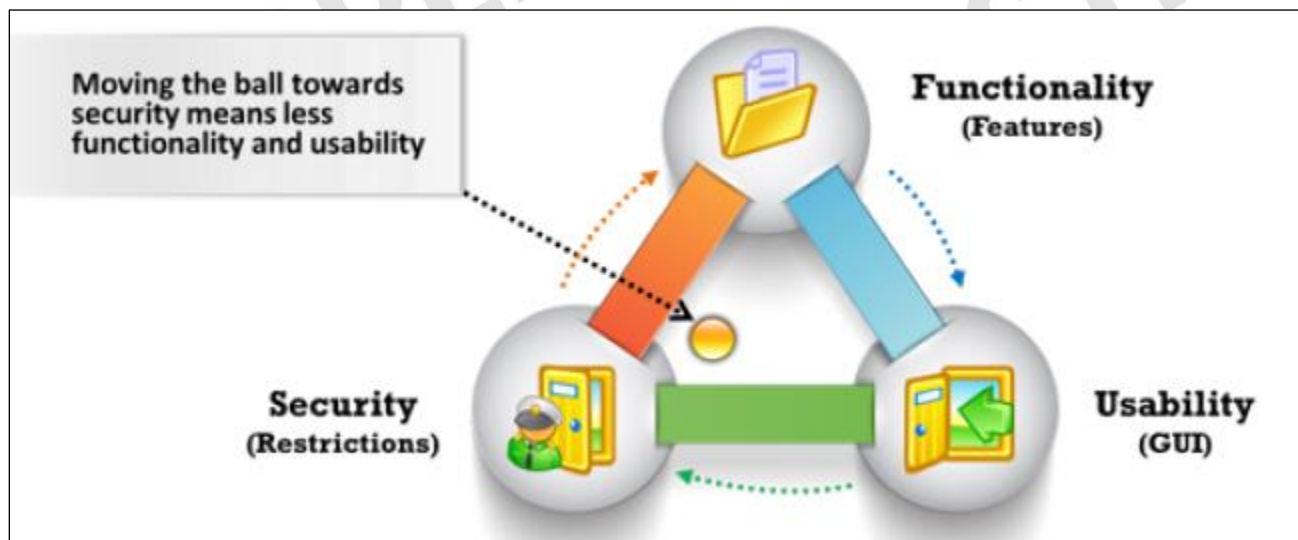


Figure 1. EC-Council. (2021). *Ethical hacking essentials (1st ed.)*. EC-Council.

The figure represents the relationships between the three (3) components. For example, if the ball moves toward security, it means increased security and decreased functionality and usability. If the ball is in the center, then all three (3) components are balanced.

For any implementation of security controls, all the components have to be considered carefully and balanced to get acceptable functionality and usability with acceptable security.

Security Challenges

The accelerating digitization benefited the IT industry but also paved the way for sophisticated cyberattacks and cybersecurity challenges. The following are some of the security challenges faced by security professionals and organizations.

- Compliance with government laws and regulations
- Lack of qualified and skilled cybersecurity professionals

- Difficulty in centralizing security in a distributed computing environment
- Difficulty in overseeing end-to-end processes due to complex IT infrastructure
- Fragmented and complex privacy and data protection regulations
- Use of serverless architecture and applications that rely on third-party cloud providers
- Compliance issues and issues with data removal and retrieval due to the implementation of Bring Your Own Device (BYOD) policies in companies
- Relocation of sensitive data from legacy data centers to the cloud without proper configuration
- Weak links in supply-chain management
- Increase in cybersecurity risks, such as data loss, unpatched vulnerabilities, and errors due to the usage of shadow IT
- Shortage of research visibility and training for IT employees

Motives, Goals, and Objectives of Information Security Attacks

A **motive** originates from the notion that a target system stores or processes something valuable, which leads to the threat of an attack on the system. The **goal** of the attack may be to disrupt the target's organization's business operations, to steal valuable information for the sake of curiosity, or even to enact revenge.

The motives and goals depend on the attacker's state of mind, their reason for carrying out such an activity, and their resources and capabilities. Once they determine their goal, they can use tools, attack machines, and methods to exploit vulnerabilities in a computer system or security policy and controls.

$$\text{Attacks} = \text{Motive (Goal)} + \text{Method} + \text{Vulnerability}$$

Motives behind information security attacks:

- Disrupt business continuity
- Perform information theft
- Manipulating data
- Create fear and chaos by disrupting critical infrastructures
- Bring financial loss to the target
- Propagate religious or political beliefs
- Achieve a state's military objectives
- Damage the reputation of the target
- Take revenge
- Demand ransom

Classification of Attacks

According to the Information Assurance Technical Framework (IATF), security attacks are classified into five (5) categories:

1. **Passive Attacks:** The intercepting and monitoring of network traffic and data flow on the target network and not tampering with the data. Attackers perform **reconnaissance**, or the initial phase where attackers gather information about a target system, network, or organization, on network activities using **sniffers** (tools to intercept and analyze data network traffic).

These attacks are difficult to detect as the attacker has no active interaction with the target system or network.

Passive attacks also capture the data or files being transmitted in the network without the consent of the user. For instance, an attacker can obtain information such as unencrypted data in transit, clear-text credentials, or other sensitive information that is useful in performing active attacks.

Examples:

- a. Footprinting (a reconnaissance technique used to gather information about a target computer system or network before attempting an attack)
 - b. Sniffing and eavesdropping
 - c. Network traffic analysis
 - d. Decryption of weakly encrypted traffic
2. **Active Attacks:** The tampering of the data in transit or disrupting communication or services between the systems to bypass or break into secured systems.

Attacks launch attacks on the target system or network by sending traffic actively that can be detected. These attacks are performed on the target network to exploit the information in transit. They penetrate or infect the target's internal network and gain access to a remote system to compromise the internal network.

Some examples:

- | | |
|---|-----------------------------|
| a. Denial-of-Service (DoS) attack | e. Spoofing attacks |
| b. Bypassing protection mechanisms | f. Replay attacks |
| c. Malware attacks (viruses, worms, ransomware) | g. Password-based attacks |
| d. Modification of information | h. Man-in-the-Middle Attack |
| | i. Backdoor access |
3. **Close-in Attacks:** These are performed when the attacker is in close physical proximity to the target system or network. The main goal of performing this type of attack is to gather or modify information or disrupt its access.

For example, an attacker might shoulder surf user credentials. Attackers gain proximity through sneaky entry, open access, or both.

Example:

- a. Social engineering (eavesdropping, shoulder surfing, dumpster diving, and other methods)
4. **Insider Attacks:** These are performed by trusted persons who have physical access to the critical assets of the target. An insider attack uses privileged access to violate rules or intentionally causes a threat to the organization's information or information systems.

Insiders can easily bypass security policies, corrupt valuable resources, and access sensitive information. They misuse the organization's assets to directly affect the confidentiality, integrity, and availability (CIA triad) of information systems.

These attacks impact the organization's business operations, reputation, and profit. It can be difficult to figure out an insider attack.

Examples:

- a. Eavesdropping and wiretapping
- b. Theft of physical devices
- c. Social engineering
- d. Data theft and *spoliation* (destruction or alteration of evidence resulting from a party's failure to preserve relevant evidence)
- e. *Pod slurping* (data theft using a portable storage device like a USB stick or a digital music player)
- f. Planting keyloggers, backdoors, or malware

5. **Distribution Attacks:** Occur when attackers tamper with hardware or software before installation. They tamper with the hardware or software at its source or when it is in transit.

Examples of distribution attacks include backdoors created by software or hardware vendors at the time of manufacture. Attackers leverage backdoors to gain unauthorized access to the target information, systems, or network.

Information Security Attack Vectors

The following lists information security vectors through which an attacker can gain access to a computer or network server to deliver a payload or seek a malicious outcome.

- **Cloud computing threats:** **Cloud computing** refers to the on-demand delivery of IT capabilities in which IT infrastructure and applications are provided to subscribers as a metered service over a network. Clients can store sensitive information in the cloud. A flaw in one client's application cloud could potentially allow attackers to access another client's data.
- **Advanced Persistent Threats (APT):** An attack that focuses on stealing information from the victim machine without its user being aware of it. These attacks are generally targeted at large companies and government networks.

As APT attacks are slow, their effect on computer performance and Internet connections is negligible. APTs exploit vulnerabilities in the applications running on computers, operating systems, and embedded systems.

- **Viruses and Worms:** These are the most prevalent networking threats and are capable of infecting a network within seconds. A **virus** is a self-replicating program that produces a copy of itself by attaching to another computer program, boot sector, or document. A **worm** is a malicious program that replicates, executes, and spreads across network connections.

Viruses make their way into the computer when the attacker shares a malicious file containing it with the victim through the Internet or any removable media. Worms enter a network when the victim downloads a malicious file, opens a spam email, or browses a malicious website.

- **Ransomware:** A malware that restricts access to the computer system's files and folders and demands an online ransom payment to the malware creator(s) in order to remove the restrictions. It is generally spread via malicious attachments to email messages, infected software applications, infected disks, or compromised websites.
- **Mobile Threats:** Attackers are increasingly focusing on mobile devices due to the increased adoption of smartphones for business and personal use and their comparatively fewer security controls.

Users may download malware-infested applications (APKs) onto their smartphones, which can damage other applications and data or reveal sensitive information to attackers. Attackers can remotely access a smartphone's camera and recording app to view user activities and track voice communications, which can aid them in an attack.

- **Botnet:** A huge network of compromised systems used by attackers to perform Denial-of-Service attacks. **Bots**, in a botnet, perform tasks such as uploading viruses, sending emails with botnets attached to them, stealing data, and so on. Antivirus programs might fail to find—or even scan

for—spyware or botnets. Hence, it is essential to deploy programs specifically designed to find and eliminate such threats.

- **Phishing:** The practice of sending an illegitimate email falsely claiming to be from a legitimate site in an attempt to acquire a user's personal or account information. This is done by distributing malicious links via some communication channel or email to obtain private information such as account numbers, credit card numbers, and mobile numbers from the victim.

Attackers design emails to lure victims in such a way that they appear to be from some legitimate source, or at times, they send malicious links that resemble a legitimate website.

- **Web Application Threats:** Attacks such as SQL injection and cross-site scripting have made web applications a favorable target for attackers to steal credentials, set up phishing sites, or acquire private information.

Most of these attacks are the result of flawed coding and improper sanitization of input and output data from the web application. Web application attacks can threaten the performance of the website and hamper its security.

- **Internet of Things (IoT) Threats:** IoT devices connected to the Internet have little or no security, which makes them vulnerable to various types of attacks.

These devices include software applications used to access the device remotely. Due to hardware constraints such as memory and battery, these IoT applications do not include complex security mechanisms to protect the devices from attacks. These drawbacks make IoT devices more vulnerable and allow attackers to access the device remotely and perform various attacks.

Information Security Laws and Regulations

Laws are a system of rules and guidelines that are enforced by a particular country or community to govern behavior. A **standard** is a document established by consensus and approved by a recognized body that provides, for common and repeated use, rules, guidelines, or characteristics for activities or their results, aimed at the achievement of the optimum degree of order in a given context.

- **Payment Card Industry Data Security Standard (PCI DSS)**

This is a proprietary information security standard for organizations that handle cardholder information for the major debit, credit, prepaid, e-purse, ATM, and POS cards.

This standard offers robust and comprehensive standards and supporting materials to enhance payment card data security. These materials include a framework of specifications, tools, measurements, and support resources to help organizations ensure the safe handling of cardholder information.

PCI DSS applies to all entities involved in payment card processing, including merchants, processors, acquirers, issuers, and service providers, as well as all other entities that store, process, or transmit cardholder data. PCI DSS comprises a minimum set of requirements for protecting cardholder data.

Failure to meet the PCI DSS requirements may result in fines or termination of payment-card processing privileges.

- **ISO/IEC 27001:2013**

From the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), this specifies the requirements for establishing, implementing, maintaining, and continually improving an information security management system within the context of an organization. It includes requirements for the assessment and treatment of information security risks tailored to the needs of the organization.

The regulation is intended to be suitable for several different uses, including:

- a. Use within organizations to formulate security requirements and objectives
- b. Use within organizations as a way to ensure that security risks are cost-effectively managed
- c. Use within organizations to ensure compliance with laws and regulations
- d. Defining new information security management processes
- e. Identifying and clarifying existing information security management processes
- f. Use by the management of organizations to determine the status of information security management activities
- g. Implementing business-enabling information security
- h. Use by organizations to provide relevant information about information security to customers

- **Health Insurance Portability and Accountability Act (HIPAA)**

The HIPAA **Privacy Rule** provides federal protections for the individually identifiable health information held by covered entities and their business associates and gives patients an array of rights to that information. At the same time, the Privacy Rule permits the disclosure of health information needed for patient care and other necessary purposes.

The **Security Rule** specifies a series of administrative, physical, and technical safeguards for covered entities and their business associates to use to ensure confidentiality, integrity, and availability of electronically protected health information.

The Office of Civil Rights implemented HIPAA's Administrative Simplification Statute and Rules, as discussed below:

- a. **Electronic Transactions and Code Set Standards:** Transactions are electronic exchanges involving the transfer of information between two parties for specific purposes.
- b. **Privacy Rule:** Establishes national standards to protect people's medical records and other personal health information and applies to health plans, health care clearinghouses, and health care providers that conduct health care transactions electronically.
- c. **Security Rule:** Establishes national standards to protect individuals' electronic personal health information that is created, received, used, or maintained by a covered entity.
- d. **Employer Identifier Standard:** Requires that each employer have a standard national number that identifies them on standard transactions.
- e. **National Provider Identifier (NPI) Standard:** The NPI is a unique identification number assigned to covered health care providers. Covered health care providers and all health plans and health care clearinghouses must use the NPIs in the administrative and financial

transactions adopted under HIPAA. The NPI is a 10-position, intelligence-free numeric identifier (10-digit number).

- f. **Enforcement Rule:** Contains provisions relating to compliance and investigation, as well as the imposition of civil monetary penalties for violations of the HIPAA Administrative Simplification Rules and procedures for hearings.
- **Sarbanes-Oxley (SOX) Act**

Enacted in 2002, the Sarbanes-Oxley Act aims to protect the public and investors by increasing the accuracy and reliability of corporate disclosures. This act does not explain how an organization must store records but describes the records that organizations must store and the duration of their storage. The Act mandated several reforms to enhance corporate responsibility, enhance financial disclosures, and combat corporate and accounting fraud.

The key requirements and provisions of SOX are organized into 11 titles:

- a. *Title I: Public Company Accounting Oversight Board (PCAOB)*
Provides independent oversight of public accounting firms that offer audit services
- b. *Title II: Auditor Independence*
Establishes standards for external auditor independence to limit conflicts of interest.
- c. *Title III: Corporate Responsibility*
Mandates that senior executives take individual responsibility for the accuracy and completeness of corporate financial reports.
- d. *Title IV: Enhanced Financial Disclosures*
Describes enhanced reporting requirements for financial transactions, including off-balance-sheet transactions, pro-forma figures, and the stock transactions of corporate officers.
- e. *Title V: Analyst Conflicts of Interest*
Discusses the measures designed to help restore investor confidence in the reporting of securities analysts.
- f. *Title VI: Commission Resources and Authority*
Defines practices to restore investor confidence in securities analysts.
- g. *Title VII: Studies and Reports*
Requires the Comptroller General and the Securities and Exchange Commission (SEC) to perform various studies and to report their findings.
- h. *Title VIII: Corporate and Criminal Fraud Accountability*
Also known as the "Corporate and Criminal Fraud Accountability Act of 2002. It describes specific criminal penalties for manipulation, destruction, or alteration of financial records or interference with investigations, while also providing certain protections for whistleblowers.
- i. *Title IX: White-Collar-Crime Penalty Enhancement*
Also known as the "White Collar Crime Penalty Enhancement Act of 2002". It increases the criminal penalties associated with white-collar crimes and corporate fraud.
- j. *Title X: Corporate Tax Returns*
States that the Chief Executive Officer should sign the company tax return.

k. *Title XI: Corporate Fraud Accountability*

Identifies corporate fraud and records tampering as criminal offenses and joins those offenses to specific penalties.

- **The Digital Millennium Copyright Act (DMCA)**

An American copyright law that implements two (2) 1996 treaties from the World Intellectual Property Organization (WIPO): the WIPO Copyright Treaty and the WIPO Performances and Phonograms Treaty.

To implement US treaty obligations, the DMCA defines legal prohibitions against circumvention of the technological protection measures employed by copyright owners to protect their works, and against the removal or alteration of copyright management information.

The DMCA contains five (5) titles:

a. *Title I: World Intellectual Property Organization (WIPO) Treaty Implementation*

Title I implements the WIPO treaties. First, it makes certain technical amendments to US law in order to provide appropriate references and links to the treaties. Second, it creates two new prohibitions in Title 17 of the U.S. Code—one on circumvention of the technological measures used by copyright owners to protect their works and one on tampering with copyright management information—and adds civil remedies and criminal penalties for violating the prohibitions.

b. *Title II: Online Copyright Infringement Liability Limitation*

Adds a new section 512 to the Copyright Act to create four new limitations on liability for copyright infringement by online service providers.

A service provider bases these limitations on the following four categories of conduct:

- Transitory communications
- System caching
- The user-directed storage of information on systems or networks
- Information location tools

c. *Title III: Computer Maintenance or Repair*

Title III of the DMCA allows the owner of a copy of a program to make reproductions or adaptations when necessary to use the program in conjunction with a computer. The amendment permits the owner or lessee of a computer to create or to authorize the making of a copy of a computer program in the course of maintaining or repairing that computer.

d. *Title IV: Miscellaneous Provisions*

Title IV contains six miscellaneous provisions. The first provision announces the Clarification of the Authority of the Copyright Office; the second grants exemption for the making of “ephemeral recordings”; the third promotes study by distance education; the fourth provides an exemption for Nonprofit Libraries and Archives; the fifth allows Webcasting Amendments to the Digital Performance Right in Sound Recordings, and, finally, the sixth provision addresses concerns about the ability of writers, directors, and screen actors to obtain residual payments for the exploitation of motion pictures in situations where the producer is no longer able to make these payments.

e. *Title V: Protection of Certain Original Designs*

Title V of the DMCA entitles the Vessel Hull Design Protection Act (VHDPA). This act creates a new system for protecting the original designs of certain useful articles that make the article attractive or distinctive in appearance. For purposes of the VHDPA, “useful articles” are limited to the hulls (including the decks) of vessels no longer than 200 feet.

- **The Federal Information Security Management Act (FISMA):**

It was enacted to produce several key security standards and guidelines required by Congressional legislation. FISMA provides a comprehensive framework for ensuring the effectiveness of information security controls over information resources that support federal operations and assets.

It requires each federal agency to develop, document, and implement an agency-wide program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source.

The FISMA framework includes:

- Standards for categorizing information and information systems by mission impact
- Standards for the minimum security requirements for information and information systems
- Guidance for selecting appropriate security controls for information systems
- Guidance for assessing security controls in information systems and determining their effectiveness
- Guidance for the security authorization of information systems

- **General Data Protection Regulation (GDPR):**

It is one of the most stringent privacy and security laws globally. Though it was drafted and passed by the European Union (EU), it imposes obligations on organizations anywhere, so long as they target or collect data related to people in the EU.

With the GDPR, Europe signifies its firm stance on data privacy and security as more people are entrusting their data with cloud services, and breaches are a daily occurrence.

GDPR Data Protection Principles

The GDPR includes seven (7) protection and accountability principles outlined in Article 5.1-2:

- **Lawfulness, fairness, and transparency:** Processing must be lawful, fair, and transparent to the data subject.
- **Purpose limitation:** You must process data for legitimate purposes specified explicitly to the data subject when you collect it.
- **Data minimization:** You should collect and process only as much data as necessary for the purposes specified.
- **Accuracy:** You must keep personal data accurate and up to date.
- **Storage limitation:** You may only store personally identifying data for as long as necessary for the specified purpose.

- **Integrity and confidentiality:** Processing must be done in such a way as to ensure appropriate security, integrity, and confidentiality (e.g., by using encryption).
- **Accountability:** The data controller is responsible for demonstrating GDPR compliance with all of these principles.

- **Data Protection Act 2018 (DPA)**

The DPA 2018 sets out the framework for data protection law in the UK. It updates and replaces the Data Protection Act 1998 and came into effect on 25 May 2018.

The DPA is an act to make provision for the regulation of the processing of information relating to individuals; to make provision in connection with the Information Commissioner's functions under specific rules relating to information; to make provision for a direct marketing code of practice and connected purposes.

The DPA also sets out separate data protection rules for law enforcement authorities, extends data protection to some other areas such as national security and defense, and sets out the Information Commissioner's functions and powers.

Protection of Personal Data

1. The DPA protects individuals concerning the processing of personal data, in particular by:
 - a. Requiring personal data to be processed lawfully and fairly, based on the data subject's consent or another specified basis,
 - b. Conferring rights on the data subject to obtain information about the processing of personal data and to require inaccurate personal data to be rectified, and
 - c. Conferring functions on the Commissioner, giving the holder of that office responsibility to monitor and enforce their provisions.
2. When carrying out functions under the GDPR, the applied GDPR, and this Act, the Commissioner must regard the importance of securing an appropriate level of protection for personal data, taking account of the interests of data subjects, controllers, and others, and matters of general public interest.

- **Cyberlaws in Different Countries**

Cyberlaw or Internet law refers to any laws that deal with protecting the Internet and other online communication technologies. Cyberlaw covers topics such as Internet access and usage, privacy, freedom of expression, and jurisdiction.

Cyber laws assure the integrity, security, privacy, and confidentiality of information in both governmental and private organizations. These laws have become prominent due to the increase in Internet usage around the world.

Cyber laws vary by jurisdiction and country, so implementing them is quite challenging. Violating these laws results in punishments ranging from fines to imprisonment.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.